

Warsaw, the 20th
of May
2024

Decision

DKN.5112.35.2021

Based on Article 104 § 1 of the Act of June 14, 1960 – Code of Administrative Procedure (Journal of Laws of 2023, item 775) in connection with Article 7 paragraphs 1 and 2, Article 60, Article 90, Article 101, and Article 103 of the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781; hereinafter referred to as the "Act of May 10, 2018"), as well as Article 57 paragraph 1 letters a) and h), Article 58 paragraph 2 letters d) and i), Article 83 paragraphs 1 – 3, Article 83 paragraph 4 letter a) in connection with Article 24 paragraph 1, Article 32 paragraphs 1 and 2, and Article 83 paragraph 5 letter a) in connection with Article 5 paragraph 1 letter f) and Article 5 paragraph 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, as amended), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative procedure regarding the violation of personal data protection regulations by A. S.A. based in U., ul. (...), the President of the Personal Data Protection Office, stating the violation by A. Spółka Akcyjna based in U., ul. (...) of the provisions of Article 5 paragraph 1 letter f) and paragraph 2, Article 24 paragraph 1, and Article 32 paragraphs 1 and 2 of Regulation 2016/679, consisting of the failure to implement:

1) appropriate technical and organizational measures ensuring the security of data processing in information systems and the protection of the rights of data subjects, based on a risk analysis taking into account the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons,

2) appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of the technical and organizational measures aimed at ensuring the security of personal data processed in information systems, particularly regarding vulnerabilities, errors, and their possible consequences for these systems, as well as the actions taken to minimize the risk of their occurrence,

resulting in a violation of the principle of integrity and confidentiality and the principle of accountability,

1. Orders A. Spółka Akcyjna based in U., ul. (...), to adjust its processing operations to the provisions of Regulation 2016/679, by:

a) implementing appropriate technical and organizational measures to minimize the risks associated with the processing of personal data, particularly those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed, after conducting a risk analysis that takes into account the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons,

b) implementing appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of measures aimed at ensuring the security of processing.

within 30 days from the date of delivery of this decision.

2. Imposes on A. Spółka Akcyjna based in U., ul. (...), for the violation of the provisions of Article 5 paragraph 1 letter f) and paragraph 2, as well as Article 32 paragraphs 1 and 2 of Regulation 2016/679, an administrative fine in the amount of 1,440,549.00 PLN (in words: one million four hundred forty thousand five hundred forty-nine zlotys).

Justification

Based on Article 33 paragraph 1 of Regulation 2016/679, a notification of a personal data breach was

submitted to the President of the Personal Data Protection Office, hereinafter referred to as the "President of UODO" or "supervisory authority", by A. Spółka Akcyjna based in U. at ul. (...), hereinafter referred to as the "Company", registered under reference number (...). The aforementioned notification was received by the President of UODO on (...) 2021 and on (...) 2021 (supplementation of the notification).

From the content of the aforementioned notifications, it was evident that the personal data breach consisted of unauthorized access by a hacker group named "A." to the Company's IT resources (network drives) and the installation of ransomware software in the Company's information system, resulting in the loss of availability and confidentiality of personal data processed by the Company in the aforementioned system. On (...) 2021, the Company confirmed the breach of data confidentiality by accessing a so-called darknet site using the address provided by the hacker group "A." On the aforementioned site on (...) 2021, a sample of personal data of the Company's employees was disseminated. The content of the darknet site of the hacker group contained a suggestion that further dissemination of the data could occur if the Company did not establish contact with them. Furthermore, the site contained information that if a ransom of (...) (in words: (...)) US dollars was paid, there would be no further dissemination of the data.

the assessment of risks associated with data processing activities. The Company implemented additional security measures in response to the identified risks, including updates to its IT systems and enhanced training for employees regarding data protection.

4. The Company has established a Data Protection Officer (DPO) who is responsible for overseeing compliance with data protection regulations and ensuring that all employees are aware of their obligations regarding personal data processing.
5. The Company has also implemented a procedure for reporting data breaches, which includes immediate notification to the DPO and the supervisory authority, as well as communication with affected individuals when necessary.
6. The Company conducts regular audits of its data processing activities to ensure compliance with applicable laws and regulations, as well as to assess the effectiveness of its data protection measures.
7. The Company has established a protocol for responding to requests from individuals regarding their personal data, including access requests, rectification requests, and erasure requests, in accordance with the rights granted to individuals under the GDPR.
8. The Company provides ongoing training and awareness programs for its employees to ensure that they understand the importance of data protection and their responsibilities in handling personal data.
9. The Company has a clear retention policy for personal data, ensuring that data is only kept for as long as necessary for the purposes for which it was collected and that it is securely deleted when no longer needed.
10. The Company has taken steps to ensure that any third-party service providers it works with also comply with data protection regulations, including conducting due diligence and entering into data processing agreements.

In conclusion, the Company has made significant efforts to comply with data protection regulations and to mitigate the risks associated with personal data processing. However, the incident involving the unauthorized access and dissemination of personal data highlights the need for continued vigilance and improvement in data security measures. The Company is committed to addressing these issues and ensuring the protection of personal data in the future.
risk analysis, which was conducted again on (...) 2021.

Furthermore, as indicated by the explanations provided by the Company after the inspection in the letter dated (...) 2023 addressed to the President of UODO, the actions taken by it after the occurrence of the personal data breach did not allow for a clear determination of the cause of the aforementioned event. Nevertheless, it should be noted that as a result of the analysis conducted by an external IT

expert engaged by the Company, Mr. W. A., described in two reports ("Report (...)") and "Report (...)"), potential vectors of "ransomware" attacks were identified. Among them, the breach of security of edge devices (...) was mentioned, caused by the lack of software updates for those devices. The administrator did provide, in principle, support from the device manufacturer that allowed for software updates, but due to the oversight of the Company's IT department employees, the required update was not actually performed. According to the Company's explanations obtained during the inspection, the Management Board was not aware of the aforementioned circumstances, as it was also not disclosed during the external audit conducted in (...) 2020, which aimed to extend the validity of the Company's ISO/IEC 27001:2013 certification. However, the aforementioned report indicated that as of the date of the hacking attack, there was an "exploit," i.e., a vulnerability resulting from a programming (configuration) error in the system, allowing for the takeover of a device operating within the Company's teleinformatics system. Moreover, as indicated in the aforementioned reports, the breach of security of edge devices (...) could have been caused by SSH and https administrative access on external interfaces. Another potential attack vector was "...", i.e., the breach of security of the cloud platform (...), through incorrect domain configuration and the use of overly weak passwords by users of the Company's system (the system administrator enforced the use of passwords containing at least (...) characters, an uppercase letter, a digit, and a special character). A "phishing" attack was also not ruled out, involving the impersonation of an attacker posing as another entity (person) to obtain specific information, e.g., related to the security of the aforementioned system, login data, or infecting it with malicious software used for such extortion, i.e., most often the "ransomware A." program (by encouraging the attacked individual to open a file containing the aforementioned malicious software). In the manner described above, it is common for the attacked workstation to be taken over by exploiting vulnerabilities in operating systems and web browsers.

The most probable attack vector was deemed to be the "phishing" attack and the exploitation of security vulnerabilities in edge devices. The number of computer workstations affected by the incident was (...), which constituted approximately (...) % of all computer workstations of the Company. The number of servers affected by the incident was (...). It was established that (...) servers with the (...) system did not have current technical support from the manufacturer (support ended in (...) 2020). Servers with the installed (...) software were domain controllers operating in read-only mode (supporting servers). As established during the inspection, according to the principles adopted by the Company regarding data minimization and storing them in appropriately designated locations due to information classification and their security, the data that was breached should have been stored in a system intended for processing health-related data, i.e., (...). According to the provision of § (...) of the "Manual (...)" applicable in the Company, employees are obliged to secure data located in the information system due to their classification, by storing them in the appropriate location.

In light of the above regulations, personal data related to the provision of health services by the Company should have been located solely in the system (...). Therefore, the placement and storage of this data in the Company's network resources (on the network drive) and on workstations was inconsistent with the principles adopted by the Company.

From the explanations obtained from the Company during the inspection, it also follows that in the course of activities determining the scope and extent of the personal data breach, undertaken by the Company after its occurrence, it was found that on workstations and on the Company's network drive there were files (...), containing data of individuals tested for COVID-19, using the Company's health services, i.e., health-related data.

In connection with the breach, the Company launched a special hotline on (...) 2021, to provide information to individuals whose personal data was affected by the personal data breach. Information about the hotline number was included in the notifications of the breach sent by the Company to the individuals concerned. Furthermore, on (...) 2021, the Company entered into an agreement with B. S.A. based in W. to enable interested individuals, whose data was concerned, to seek information regarding entries in B. S.A. based in W.

In light of the aforementioned findings, the inspectors identified irregularities consisting of the selection

of inappropriate technical and organizational measures to minimize the risk associated with the processing of personal data, particularly arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed, as a result of improperly conducted risk analysis, and the lack of
Regular testing, measuring, and assessing the effectiveness of measures to ensure the security of processing.

In connection with the above, the President of the Personal Data Protection Office (UODO) on (...) 2022 initiated ex officio administrative proceedings regarding the possibility of a violation by the Company, as the administrator, of the obligations arising from the provisions of Article 5(1)(f), Article 5(2), Article 24(1), and Article 32(1) and (2) of Regulation 2016/679 (reference:).

The Company, in a letter dated (...) 2022, responded to the allegations of the President of UODO regarding the identified violations of personal data protection regulations, which are the subject of the administrative proceedings mentioned in the notification of the initiation of proceedings. The Company indicated that:

1. In its opinion, the applicable regulations do not explicitly provide a closed, enumerative catalog of technical and organizational measures that the administrator should apply, and the assessment of their adequacy requires a thorough technical analysis and consideration of the applicable standards for a given sector or branch of the economy. The Company raised that the notification of the initiation of proceedings in this matter does not refer to any standards, guidelines, or requirements issued by relevant authorities, associations, or working groups and "duplicates the findings made in the 'Report (...)', prepared at the request of the Company after the occurrence of a personal data breach."
2. The aforementioned report constitutes an IT analysis of the breach, indicating potential attack vectors, but not definitively determining which of them was actually exploited. In the Company's opinion, the analysis resulting from the aforementioned report does not take into account issues related to personal data protection, e.g., the degree of adequacy to the risk and does not comprehensively address organizational measures, e.g., appropriate procedures, actual actions, and ongoing activities conducted by the Company;
3. It meets the requirements of the ISO/IEC 27001:2013 standard and is subject to regular audits in this regard, and the information in this respect, the certificate, and the report from 2020 were provided during the inspection by the President of UODO. In the Company's opinion, the acceptance of the conclusions of the aforementioned IT analysis ("Report (...)") by the President of UODO, i.e., the acceptance of the fact of violation of the provisions of Regulation 2016/679 without making "additional findings," conducting its own analysis, or inspections by the President of UODO, in the Company's view leads to "erroneous conclusions regarding the significance of the deficiencies for the subject matter of the case." The Company indicated that, in its opinion, the indicated deficiencies, considering the industry standards existing at the time of the breach, i.e., the lack of binding legal requirements for the medical sector and the necessity to maintain proportionality of the steps taken to available budgetary resources, also in the context of actions necessary for organizing remote work for part of the staff due to the pandemic period, did not significantly deviate from the level of security in typical medical establishments.

However, one cannot agree with the Company's assertion raised in the aforementioned letter that the personal data breach, in connection with which the President of UODO conducted the inspection, was an incident whose factual circumstances are similar to such an extent to the circumstances of the event that is the subject of the decision of the President of UODO in the case with reference number (...) dated (...) 2021, that it would justify applying the same sanction to the Company as in the aforementioned case. Although the supervisory authority in the case with reference number (...) also identified irregularities regarding the technical and organizational measures employed by the party to the proceedings (incorrect, unreliable preparation of the risk analysis, use of operating systems and IT systems for processing personal data without technical support from their manufacturer, lack of built-in and updated security measures increasing the risk of infection by malware and attacks through the

emergence of new vulnerabilities, irregular testing, measuring, and assessing of security measures), in the cited case, there was no loss of data confidentiality as occurred in the present case.

In this factual state, after reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following:

According to Article 32(1) and (2) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of violation of the rights or freedoms of natural persons with varying probabilities of occurrence and severity of the threat, the administrator and the processor implement appropriate technical and organizational measures to ensure a level of security appropriate to that risk, including, where appropriate: a) the pseudonymization and encryption of personal data; b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services; c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident; d) regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processing (paragraph 1). In assessing whether the level of security is appropriate, particular attention is paid to the risks associated with processing, in particular those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed (paragraph 2).

Furthermore, pursuant to Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing as well as the risk of violation of rights or...

****Freedom of Individuals with Varying Probability and Severity of Threat****

The administrator implements appropriate technical and organizational measures to ensure that processing is carried out in accordance with Regulation 2016/679 and to be able to demonstrate this. These measures are reviewed and updated as necessary.

In turn, in light of Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("integrity and confidentiality").

Article 5(2) of Regulation 2016/679 establishes the principle of accountability, according to which the administrator is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate such compliance.

From the aforementioned provisions, it follows that a risk-based approach to managing personal data protection constitutes a fundamental concept underlying Regulation 2016/679. This means that it becomes necessary to demonstrate to the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk and take into account the nature of the organization and the mechanisms used for data processing. The consequence of such an orientation is the abandonment of the lists of security requirements imposed by the legislator in favor of independently selecting safeguards based on a threat analysis. Administrators are not provided with specific security measures and procedures, and their determination should occur in a two-step process. First, it is necessary for the administrator to determine the level of risk of infringement of the rights or freedoms of individuals associated with the processing of their personal data, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk and to achieve compliance with the provisions of Regulation 2016/679.

According to Recital 75 of the preamble to Regulation 2016/679, the risk of infringement of the rights or freedoms of individuals with varying probability and severity may arise from the processing of personal data that could lead to physical harm or material or non-material damage, in particular: if the processing could result in discrimination, identity theft, or identity fraud, financial loss, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; if the individuals

whose data are processed may be deprived of their rights and freedoms or the ability to exercise control over their personal data; if personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership are processed; and if genetic data, data concerning health, or data concerning sexuality or criminal convictions and offenses or related security measures are processed; if personal factors are assessed, in particular analyzed or predicted aspects concerning work performance, economic situation, health, personal preferences or interests, reliability or behavior, location or movement – for the purpose of creating or using personal profiles; or if data of individuals requiring special protection, in particular children, are processed, and if the processing concerns a large amount of personal data and affects a large number of individuals whose data are processed.

The EU legislator also signals through Recital 76 of the preamble to Regulation 2016/679 that the probability and severity of the risk of infringement of the rights or freedoms of the data subject should be determined by referring to the nature, scope, context, and purposes of the data processing. The risk should be assessed based on an objective evaluation, within which it is determined whether the data processing operations involve risk or high risk.

Recital 83 of the preamble to Regulation 2016/679 indicates that in order to maintain security and prevent processing that is not in accordance with Regulation 2016/679, the administrator should assess the risk specific to the processing and implement measures – such as encryption – to minimize that risk. When assessing the risk regarding data security, consideration should be given to the risks associated with the processing of personal data – such as accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed – which may in particular lead to physical harm, material or non-material damage.

In reference to the above-mentioned provisions and recitals of Regulation 2016/679, as well as taking into account the factual circumstances established by the President of the Personal Data Protection Office during the inspection and administrative proceedings, it should be stated that the Company improperly conducted the risk analysis dated (...) 2021 (document dated (...) 2021 titled “(...)”), i.e., in the sections “Use of (...)” (threat category “IT”) and “Occurrence of (...)” (threat category “IT”), risks associated with the processing of data in the IT systems (resources) of A. Spółka Akcyjna were defined at too low, inadequate levels in relation to the degree of threat. In the position titled “Use of (...)” (threat category threats “IT”) in the aforementioned risk analysis, the level of risk for most processing activities and purposes was determined to be “low” (with the processing activity/purpose “Data (...)” rated as “minimal”). Furthermore, in the section “Occurrence (...)” (threat category “IT”), the level of risk for all data processing activities and purposes was classified as “medium.” In other words, the Company did not underestimate the risks associated with its use of software without manufacturer support, including, among others, its updates, as well as the risks associated with incorrect domain configuration. The risk was classified as “medium,” despite the absence of a detailed testing, measuring, and evaluating procedure for the effectiveness of security measures within the Company. The lack of such a procedure in itself resulted in the inability to regularly test, measure, and evaluate the measures aimed at data protection (the absence of the aforementioned regularity was confirmed during the inspection), and consequently hindered the proper preparation of the risk analysis due to the inability to fully identify and assess the risks associated with the processing of personal data using information systems. Additionally, the Company did not adequately consider in the risk analysis the risks associated with processing, particularly those arising from accidental or unlawful destruction, loss, modification, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed, i.e., the Company did not take into account in the said document the risk related to setting too weak a password for users of the Company’s information system (password for (...) – the omission of such a category in the analysis), as well as the risk associated with not conducting regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of processing (such a category was not included in the analysis). Indeed, in the document “(...)” dated (...) 2021, the threat generally referred to as “Incorrect (...)” was

included (the level of risk for this threat was assessed by the Company as “medium”), however, according to the President of the UODO, it cannot be unequivocally stated that the aforementioned term also encompasses the issue of setting access passwords with appropriate security strength. It should be noted that the level of risk assessed by the Company as “medium” (and even “low” in relation to the processing of “Employees (...)”) regarding the aforementioned threat should be evaluated, similarly to the other aforementioned cases, as too low, considering the actual errors identified during the UODO inspection in the settings of the Company’s IT equipment, as well as the experience arising from the circumstances of the data protection breach prior to the preparation of the risk analysis dated (...) 2021.

It should be added that in the section titled “Use of information systems without support” (threat category “IT”) of the aforementioned risk analysis (document dated (...) 2021 titled “(...”), not only was the level of risk for most processing activities and purposes determined to be “low” (with the processing activity/purpose “Research data – veterinary experiences” rated as “minimal”), but it was additionally assessed that in the case of the aforementioned risk, “no actions [are] required.” This was done despite the fact that among the identified potential attack vectors of “ransomware,” described in the document “Report on the analysis of the current state of security,” prepared at the Company’s request following the occurrence of the data protection breach, the compromise of the security of edge devices (...) was mentioned, caused by the lack of software updates for those devices. Furthermore, the threat named “Occurrence (...)” (threat category “IT”) was classified with a risk level of “medium” for all data processing activities and purposes.

In turn, regarding the threat named “Incorrect (...)”, the Company assessed the risk level as “medium,” and even “low” in relation to the processing of “Employees (...)”.

In light of the above, it should therefore be recognized that the identification of risks associated with data processing in the Company’s information systems (including those without manufacturer support) occurred at a level inadequate to the level of threat. In other words, this analysis was not conducted in a manner that would provide the Company, as the administrator, with a basis for implementing appropriate technical and organizational measures to ensure a level of security commensurate with the risk of infringement of the rights or freedoms of individuals, considering the varying likelihood and severity of the threat, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing. This assessment is also justified by the fact that the estimations and determinations of the aforementioned risk levels were made after the occurrence of the personal data breach that lasted from (...) to (...) 2021, thus an event whose occurrence clearly indicated a high degree of the aforementioned risks, especially since the Company did not regularly test the effectiveness of the security measures used for processing personal data in information systems, nor did it implement – contrary to the requirements of Article 32(1) and (2) of Regulation 2016/679 – a procedure for such testing, thereby depriving itself of a significant means for a reliable assessment of the level of the aforementioned risks. The Company’s assumption in such a situation that the aforementioned risks are at a low or medium level was, in the opinion of the President of the UODO, an action devoid of basis, i.e., made based on apparent and unverified premises. It should be added that the violation of the aforementioned provisions of Regulation 2016/679 also occurred due to the Company’s failure to determine the cause of the data protection breach after its occurrence, thus the Company was unable to take this into account in the risk analysis. from the date of (...) 2021, the factors that triggered the aforementioned event and reliably determined the level of associated risk, resulted in the incompleteness of the document dated (...) 2021 titled “(...)”. It should be emphasized that even if hypothetical risk factors that could potentially cause a violation of personal data protection were included in the analysis prepared by the Company, this inclusion occurred without the possibility of properly assessing the levels of risks. The Company’s lack of awareness in the above-mentioned regard (concerning the causes of the incident) must lead to a situation where the risk analysis does not fully reflect the actual risk factors and their degree. Thus, the risk analysis was deprived of key information allowing the Company to consciously and systematically minimize specific risks associated with data processing and to avoid (or at least reduce) the

occurrence of data protection violations in the future.

It should be noted that the Company's violation of Article 24(1) and Article 32(1) and (2) of Regulation 2016/679 also resulted from the improper conduct of the risk analysis prior to the occurrence of the data protection violation (document "(...)" dated (...) 2020). As follows from the content of this document, under the entries defining threats named "Occurrence (...)" and "Incorrect (...)", the level of risk was assessed as "medium". The determination of risk at the aforementioned level before the occurrence of the personal data protection violation, in the opinion of the President of the UODO, was inadequate to the actual state of affairs, considering the fact of the occurrence of a personal data protection violation, as well as the findings of the inspection regarding the course of the aforementioned incident and the irregularities in the organizational and technical measures applied by the Company to ensure the security of processed data. The assessment of risk as "small" or even "minimal" (e.g., in the processing activity "Processing (...)") in the entry "Use (...)" is also not deserving of approval. This action should be considered erroneous and inconsistent with the provisions of Regulation 2016/679, taking into account the fact that support from the software manufacturer used for data processing is widely regarded in the IT industry as a fundamental principle of security. This is also confirmed by the applicable technical standards[1], as well as by the guidelines of the European Data Protection Board (hereinafter: EROD)[2].

It should therefore be stated that the assumption before the occurrence of the data protection violation of a "small" level of risk materialization of the threat named "Use (...)" for most processing activities and purposes was an action devoid of real, fact-based conditions. Furthermore, as indicated above, it was contrary to commonly accepted standards in the IT industry, as well as the guidelines of EROD. Maintaining and using information systems that have lost manufacturer support, as well as devices equipped with unsupported software, always poses a threat to the security of the data processed using them, as in this way the administrator consciously deprives themselves of the ability to respond to current IT threats that have a direct impact on data security. Therefore, since the Company, as the administrator, decided to use such devices, and in addition, as a result of the risk analysis conducted both before (analysis dated March 30, 2020) and after the occurrence of the personal data protection violation (analysis dated August 2, 2021), assessed the level of risk of this threat as "small", it should be considered that such action, especially in light of the occurrence of the aforementioned violation, was disproportionate to the level of threat and the principles of information security commonly applied in the field of IT.

Regarding the allegation against the Company concerning the improper conduct of the risk analysis, including the assessment of the degree of some risks at too low a level, the Company explained in a letter dated (...) 2022 that "The Authority refers to the risk analyses carried out taking into account the methodology and risk levels adopted in the Administrator's organization (the procedure (...) provided to the Authority)." The Company also indicates that "the higher assessment indicated by the Authority, within the framework of the Administrator's methodology, would require the acceptance of the probability of '(...)', which means that the risk is 'very likely' — it is expected that threats will occur in most cases or circumstances and there is full knowledge regarding past occurrences, consequences, and causes. (...) at the time of preparing the analysis (i.e., (...) 2021), it could not be assumed that the occurrence of the event (another infection of the systems) is very likely. It was always real, but not very likely. The mere existence of potential security vulnerabilities, for which remedial actions were initiated, cannot determine a high probability of an external attack, dependent on the actions of third parties and knowledge or identification of the aforementioned vulnerabilities."

The above-quoted argumentation of the Company cannot be agreed with. Given the occurrence of the personal data protection violation, its "mechanism," scale, and nature, the Company's classification of the level of risk for most processing activities and purposes as "small" (for the processing activity/purpose "Data (...)" as "minimal"), as well as the determination in the entry "Occurrence (...)" (threat category "IT") of the risk level for all processing activities and purposes as "medium," was, in the opinion of the President of the UODO, inadequate to the actual state of affairs. This, in turn, consequently led to the application of insufficient organizational and technical measures to ensure the

security.

personal data.

As indicated above, the Company underestimated the significance and scale of the violation of personal data protection, which should have served as a reliable reference point for it when conducting another risk analysis. Furthermore, it clearly either did not precede the aforementioned analysis with appropriate review activities regarding the current state of updates and configuration of its IT system or, despite conducting them, ignored their results, as it assessed the level of risk as "low" and "medium," even though during the inspection, deficiencies were identified, such as the lack of software updates. This indicates that the risk assessment was conducted inaccurately, i.e., without duly considering the actual state of security of the Company's IT systems, and above all, without taking into account the element of life experience, which is associated with the Company's awareness of the occurrence of a similar event in the past, namely, a violation of personal data protection (in relation to the risk analysis contained in the document "(...)" dated (...) 2021, i.e., after the occurrence of the personal data protection violation). It should be noted once again that the document assessing the level of risks for individual processing processes did not adequately consider the degree of risk associated with the Company's use of software without the manufacturer's support, including, among others, its updates, the risk related to incorrect domain configuration, the risk concerning the setting of too weak a password for users of the Company's IT system (password for (...)), as well as the risk associated with the failure to conduct regular testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of processing. Events related to the aforementioned risks occurred within the framework of the report submitted to the President of the UODO prior to the inspection of the personal data protection violation; therefore, the Company, aside from the fact that it ignored the current technical standards for the security of information and personal data processed in IT systems, cannot claim in its defense that, for example, processing data in unupdated or unsupported IT systems did not involve high risks of the materialization of these threats, since it itself did not sufficiently assess the level of such risks when selecting technical and organizational measures or did not consider them at all (e.g., in the case of the failure to implement software updates due to negligence by employees), as evidenced by the content of the document it presented during the inspection dated (...) 2021 titled "(...)". Importantly, and worth reiterating, the aforementioned document was prepared after the occurrence of the personal data protection violation, and thus at a time when the Company was aware of the risks and threats associated with the use of its IT system for processing personal data, and the aforementioned incident should have prompted it to thoroughly analyze all factors related to the operation of its IT system, including issues such as the lack of manufacturer support for the installed software, improper configuration of settings, etc. Therefore, taking into account, in particular, the broad scope of personal data processed by the Company in the resources of network drives operating within its IT system, as well as, among others, the number of individuals (...), whose data are affected and who were impacted by the consequences of the personal data protection violation, in order to properly fulfill the obligations arising from the provisions of Regulation 2016/679, the Company was obliged to take actions ensuring an appropriate level of personal data protection by implementing appropriate technical and organizational measures to ensure the security of their processing, as well as to regularly test, measure, and assess the effectiveness of the aforementioned measures. Decisions regarding the nature, types, or intensity of such actions should be based on the conclusions resulting from the risk analysis conducted for the processing operations, taking into account, among others, vulnerabilities, threats, possible consequences of violations, and security measures aimed at ensuring the confidentiality, integrity, and availability of processed personal data, as well as the experience resulting from the personal data protection violation that occurred before the risk analysis dated (...) 2021. Meanwhile, the gathered evidence indicates that the Company managed IT resources located outside the medical IT system (...), in which it processed personal data of its patients and employees, without properly analyzing the associated risks, not regularly testing the IT systems and their security, and as a result of the above – not applying adequate technical and organizational measures for data protection. In the opinion of the President of the UODO, the implementation of technical measures by the Company, while simultaneously underestimating the risks associated with processing data using a wrongly configured

IT system, equipped with software lacking manufacturer support and updates (as well as not regularly tested, measured, and assessed for data security effectiveness), did not provide adequate assurance that these measures would be appropriate, adequate, and effectively minimize the risk of violation of the rights or freedoms of individuals whose data are concerned. The above position of the supervisory authority is also reflected in the judgment of the Provincial Administrative Court in Warsaw dated August 26, 2020 (case no. II SA/Wa 2826/19, Legalis no. 2480051), in which the Court stated that Article 32(1) of Regulation 2016/679 "(...) does not require the data controller to implement of any technical and organizational measures that are intended to serve as means of protection for personal data, but require the implementation of adequate measures. Such adequacy should be assessed in terms of the manner and purpose for which personal data is processed, but it is also necessary to take into account the risk associated with the processing of such personal data, which may vary in magnitude." At the same time, the Court emphasized that "[t]he adopted measures should be effective; in specific cases, some measures will need to mitigate low risk, while others must mitigate high risk; however, it is important that all measures (as well as each one individually) are adequate and proportional to the level of risk." Furthermore, in the judgments of May 13, 2021, case no. II SA/Wa 2129/20, and October 5, 2023, case no. II SA/Wa 502/23, the Provincial Administrative Court in Warsaw indicated that "the data controller should (...) conduct a risk analysis and assess what threats it is dealing with."

In the latter judgment, the Court also emphasized that "the supervisory authority is not obliged to indicate to the Controller the technical and organizational solutions that it should implement to ensure that the processing of personal data is carried out in accordance with the law. It is the responsibility of the Controller to implement these measures and then, if necessary, demonstrate that it complies with the principles of personal data processing set out in Regulation 2016/679, in accordance with the principle of accountability (Article 5(2) of the aforementioned regulation)."

Due to the improper conduct of the risk analysis related to processing, including the failure to adequately consider the aforementioned risks associated with using software without the manufacturer's support, its updates, incorrect domain configuration, setting too weak a password for users of the Company's IT system (password for (...)), and not conducting regular testing, measuring, and evaluating the effectiveness of technical and organizational measures aimed at ensuring the security of processing, the Company was unable to demonstrate that, in implementing technical and organizational measures to ensure compliance of processing with Regulation 2016/679, and also assessing whether the level of security of personal data is appropriate, it actually took into account the criteria described in Article 32(1) of Regulation 2016/679, including the risk of infringement of the rights or freedoms of natural persons, as well as the risks associated with processing, particularly those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data, in accordance with the obligation arising from Article 32(2) of Regulation 2016/679.

As also noted in the literature on the subject (P. Barta, P. Litwiński, M. Kawecki, Commentary on Article 5, in: General Data Protection Regulation. Personal Data Protection Act. Selected Sectoral Provisions. Commentary, ed. P. Litwiński, Legalis 2021), "[a]ccountability, which in particular includes the obligation to demonstrate compliance with legal provisions, consists, in the opinion of the Article 29 Working Party [Opinion of July 13, 2010, 3/2010 on the principle of accountability (WP 173), (...)] of the following partial obligations: 1) the obligation to implement measures (including internal procedures) that guarantee compliance with data protection regulations in connection with their processing operations; 2) the obligation to prepare documentation that informs the data subjects and supervisory authorities about the measures taken to ensure compliance with data protection regulations.

(...) In this sense, accountability should therefore be understood as a certain property of processing activities, allowing for the demonstration of compliance with legal provisions regarding operations on personal data, particularly through documentation of data protection. The consequence of the principle of accountability is that in the event of a dispute with the data subject or with the supervisory authority, the controller should be able to present evidence that it complies with data protection regulations. Such

evidence may primarily consist of documents describing the principles of processing and protecting personal data."

In light of the above, it should be noted that the functioning of any organization, especially in the area of personal data protection, cannot be based on unreliable or unrealistic foundations, and neglecting the fundamental information that every controller should regularly obtain regarding the state of the organizational and technical measures it employs, particularly as a result of their testing, measuring, and evaluating, may lead to a false sense of security, resulting in the controller failing to take actions it is obliged to undertake, which in turn may result, as in the present case, in a breach of personal data protection, causing – due to the scope of personal data subject to the breach – a high risk of infringement of the rights or freedoms of natural persons.

The improper conduct of the risk analysis demonstrated above resulted in the failure to implement appropriate technical measures for the security of personal data processing. Risk analysis is fundamental for the proper selection of the aforementioned measures, as determining the types of risks and their levels dictates the application of appropriate solutions for the specific controller's situation. During the inspection, the following irregularities were identified in the technical measures applied by the Company, as the controller: a) lack of updates to the software of edge devices, i.e., on the day of the personal data breach, there was an "exploit" allowing for the takeover of edge devices, b) enabled administrative SSH access.

i. https on external interfaces of edge devices, which could have led to the breach of security of the aforementioned devices and subsequently to gaining access to the Company's teleinformatics infrastructure and the personal data processed therein, c) incorrect domain configuration and the use of weak passwords by users, which increased the possibility of unauthorized acquisition of authorization data (passwords) by third parties; the minimum password length set by the Company was only (...) characters, which did not correspond to current practices in the IT industry (the standard at the time of the audit was 12 characters)[3], d) incorrect configuration of the Company's domain and the installation of tool software on the domain controller, which, if taken over by an attacker, could facilitate further operations, e.g., taking over a user account, installing software that would allow access to additional IT resources, e) installation of tool software on the Company's domain controller, which, if taken over by an attacker, could facilitate further operations in the Company's teleinformatics infrastructure, f) use of servers with the system (...), which did not have current technical support from the manufacturer (for about 1 year prior to the incident; support ended in (...) 2020), thus increasing the risk of occurrence and exploitation by unauthorized persons of vulnerabilities in the IT system, g) failure to conduct regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processing, resulting in an increased risk of the aforementioned irregularities and the inability to identify their occurrence by the Company before the occurrence of a personal data breach.

Identified critical vulnerabilities, such as: lack of software updates for edge devices, configuration (...) inconsistent with best practices in the IT industry at the time of the audit and EROD guidelines (mentioned above), unsupported operating systems on domain controllers and workstations, and the installation of tool software on the domain controller, were described in the "Report (...)", prepared by the Company after the occurrence of the personal data breach. The above constitutes evidence that the Company was aware of the existence of the aforementioned irregularities at the time of the audit, yet did not take actions aimed at eliminating them. Furthermore, the violation of the aforementioned provisions of Regulation 2016/679 resulted from the Company's failure to regularly conduct testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of data processing.

In the judgment of June 6, 2023, case file II SA/Wa 1939/22, the Provincial Administrative Court in Warsaw stated that "(...) the obligation to regularly test technical and organizational measures securing the processing of personal data, in order to ensure a level of security corresponding to the risk, in the sense of Article 32(1) introductory sentence of the GDPR, directly arises from the wording of letter d of the cited Article 32(1), while the obligation to document actions in this regard is

established by the principle of accountability (Article 5(2) of the GDPR)." Similarly, this Court expressed itself in the judgment of June 21, 2023, case file II SA/Wa 150/23.

It should also be emphasized that the aforementioned testing, measuring, and assessing of technical and organizational measures to ensure security in processing, in order to fulfill the requirement arising from Article 32(1)(d) of Regulation 2016/679, must be conducted regularly, which means consciously planning and organizing, as well as documenting such actions within specified time intervals, regardless of changes in the organization and the course of data processing processes (in connection with the principle of accountability referred to in Article 5(2) of Regulation 2016/679). The Company did not demonstrate during the audit or in the course of the administrative proceedings that it conducted the aforementioned activities regularly. The only manifestation of testing, measuring, and assessing in the area of technical measures used by the Company were activities conducted by the Company, which preceded its obtaining a certificate in the scope of the ISO/IEC 27001:2013 standard.

However, it should be noted that the aforementioned activities were incidental and one-time, as they were conducted only in connection with the recertification related to the ISO/IEC 27001:2013 standard. By regularity, one should understand a situation in which the aforementioned activities would be conducted at specified intervals of time, not subject to randomness, but determined by the principles adopted by the Company for conducting tests, and thus also their frequency, developed with consideration of the scale, nature, and manner of data processing. The Company did not develop the aforementioned principles nor did it conduct testing in a regular manner in practice.

Responding to the Company's assertions contained in letters dated (...) 2022 and (...) 2023 addressed to the President of UODO after the audit, it should be stated that they do not contain arguments that deserve consideration in the examination of this matter and that would contradict the conclusions drawn based on the collected evidence. The letter dated (...) 2022 contains the erroneous thesis that the President of UODO, initiating administrative proceedings against the Company and indicating a violation of the provisions of Regulation 2016/679 in the letter dated (...) 2022 (reference: (...)), was guided mainly, if not solely, by the content of the "Report (...)" prepared at its request after the occurrence of the personal data breach. In light of the above, it should be stated that the aforementioned document,

although it was taken into account by the President of the UODO when considering this case, the post-control findings and the allegations made against the Company were formulated primarily based on the applicable legal provisions and the assessment of the factual circumstances established by the inspectors as described in the inspection report, resulting from the evidence gathered during the inspection, as well as based on currently accepted and widely known basic data security standards in the IT industry, which will be discussed in more detail later in this decision. It should also be noted that the allegations made against the Company by the President of the UODO in this proceeding, contrary to the Company's suggestion, do not determine the direct cause of the data protection violation. However, this does not change the fact that the inspection by the President of the UODO revealed a number of violations of the provisions of Regulation 2016/679 committed by the Company, regardless of whether they had a direct impact on the occurrence of the personal data breach or not.

In the judgment of February 9, 2023 (case no. III OSK 3945/21), the Supreme Administrative Court indicated in its justification that "in administrative law, an individual is liable for an administrative offense, not for a wrongful act consisting of behavior or omission. This liability is objective, not subjective. An administrative offense may thus constitute a certain action, but also a certain objectively existing state of affairs for which the individual is responsible. The Constitutional Tribunal emphasizes in its jurisprudence that with respect to administrative offenses, the subsumption of the factual state comes down to determining whether a specific action fulfilled the characteristics indicated in the statute (judgment of the Constitutional Tribunal of October 14, 2009, Kp 4/09, OTK-A 2009, no. 9, item 134). In such a situation, an administrative offense does not have to constitute an act at all, and even more so, it is not required to specify in the decision the administrative offense for which the party bears legal responsibility." In the aforementioned judgment, the Supreme Administrative Court also indicated that "the administrative sanction for violating the obligations specified in Article 32 of the GDPR applies not

to the one who, as the administrator or processor, allowed unauthorized processing of personal data, but only to the entity that did not maintain the appropriate standard of security measures in the given circumstances. An individual is not liable for the illegal actions of a third party (e.g., a hacker) consisting of unauthorized access to data processed by them, but for allowing such access due to an inadequate level of security measures applied. The mere circumstance of unauthorized access to data does not determine a violation of the cited provision, as such a state of affairs is potentially possible even with the highest level of security measures in place. This interpretation is reinforced by the content of Recital 76 of the GDPR, which states that <<[r]isk should be assessed based on an objective evaluation, within which it is determined whether the processing operations involve risk or high risk>>."

The Company's assertion that the supervisory authority, in formulating allegations against it, did not refer to any standards concerning the IT industry is unfounded. It should be noted that, for example, the requirement and obligation of the data administrator to provide ongoing support regarding software updates, e.g., for edge devices and software in the form of a system (...) installed on the Company's servers (support ended in (...) 2020, thus significantly before the inspection date), falls within the realm of commonly known knowledge in the IT industry. This knowledge is widely recognized even among a broad group of non-professional users of IT devices, e.g., regarding the necessity of updating environmental software (Windows, Linux) on computers, in order to, among other things, install additional security measures protecting against hacking attacks, etc. Therefore, it is difficult to assume that the aforementioned knowledge is absent among IT specialists employed by a computerized, professional entity conducting business activities, such as the Company.

It should therefore be emphasized that ensuring the ongoing update of software that has, as mentioned above, significance for information security, and consequently, also for the security of personal data, is a fundamental, undisputed, and widely known obligation of the administrator. Evidence of neglecting the aforementioned threat is the fact that in subsequent risk analyses conducted by the Company, the level of risk associated with this factor was deemed to be at a "low" level.

At the same time, the argument put forward by the Company that there are no applicable standards sanctioned by legal provisions in this regard and that the irregularities pointed out by the President of the UODO to the Company are not directly included in the closed, enumerative catalog of technical and organizational measures that the administrator should apply cannot be considered as introducing new circumstances to the case. Standards requiring the administrator, among other things, to update system software and ensure data security (antivirus, firewall, etc.), as indicated above, are widely accepted in the IT industry and must be addressed in this matter. Additionally, regarding the obligation to update system software, such as the system (...) installed on the Company's servers, on the date of the occurrence of the data protection breach, for example, the standard PN-EN ISO/IEC 27002 Chapter 12.5.1 letter a) "Installation of software in production systems" was in force. This standard clearly indicates the necessity of updating software to ensure information security. and thus also personal data. The above reasoning applies equally to the issue of the lack of updates to the software of edge devices used by the Company in its IT system. It should be noted once again that the Company, in the document position "(...)" titled "Use of (...)" (threat category "IT"), defined the risk level for most processing activities and purposes as "low," thereby unjustifiably concluding that software updates are of rather marginal importance for the security of its IT system. Similarly, the other shortcomings of the Company regarding the technical measures (IT) mentioned in Article 24(1) and Article 32(1) of Regulation 2016/679 should be assessed, namely the enabled SSH administrative access and HTTPS on external interfaces of edge devices, incorrect domain configuration, and the use of excessively weak passwords by users, which increased the possibility of unauthorized acquisition of authentication data (passwords) by third parties. The minimum password length for (...) set by the Company as the administrator at only (...) characters did not correspond to current practices in the IT industry (the standard at the time of the audit was 12 characters). It should be emphasized that the strength of the password set by the Company at the time of the audit (and at the time of the personal

data breach) did not even meet the requirements specified a long time ago, as far back as 2004, namely in the repealed regulation of the Minister of Internal Affairs and Administration of April 29, 2004, on the documentation of personal data processing and the technical and organizational conditions that devices and IT systems used for processing personal data should meet (Journal of Laws 2004 No. 100, item 1024). A password of at least 12 characters was a commonly accepted and used market standard in the field of IT security at the time of the audit by the President of the UODO. In this regard, the selection of a password (its strength) according to the level of threat is also provided for by the standard PN-EN ISO/IEC 27002 Chapter 9.4.3. "Password Management System" letter c).

In the context of the above reasoning, reference should also be made to the content of the EROD Guidelines 01/2021 on examples of reporting personal data breaches adopted on December 14, 2021, version 2.0. In Chapter 2.5 "Organizational and technical measures to prevent the consequences of ransomware attacks and mitigate them," EROD formulated the following recommendations: "48. The fact that a ransomware attack may have occurred is usually a sign of at least one vulnerability in the administrator's system. This also applies to cases of ransomware where personal data has been encrypted but has not been exfiltrated. Regardless of the outcome and consequences of the attack, the importance of a comprehensive assessment of the data security system – with particular emphasis on IT security – cannot be overstated. Identified weaknesses and vulnerabilities in security must be documented and promptly addressed. 49. Recommended measures: (The list of the following measures is by no means exclusive or exhaustive. The aim is rather to present ideas for preventing attacks and possible solutions. Each data processing activity is different, so the administrator should decide which measures are most suitable for the given situation.) - updating firmware, operating system, and application software on servers, client computers, active network components, and all other devices on the same LAN (including Wi-Fi devices). Ensuring appropriate IT security measures, ensuring they are effective, and regularly updating them in case of changes or developments in processes or circumstances. This includes maintaining detailed logs that record information about what patches were applied at a given timestamp; - designing and organizing processing systems and infrastructure to segment or isolate data systems and networks to avoid the spread of malware within the organization and to external systems; - having a current, secure, and verified backup procedure. Media for medium- and long-term backups should be stored separately from the operational data storage and out of reach of third parties, even in the event of a successful attack (e.g., daily incremental backup and weekly full backup); having/obtaining an appropriate, current, effective, and integrated malware protection program (...).

It should be noted that administrators are obliged not only to achieve compliance with the guidelines of Regulation 2016/679 through a one-time implementation of technical and organizational security measures but also to ensure the continuity of monitoring the scale of threats and accountability regarding the level and adequacy of the implemented security measures. As noted in the literature on the subject (P. Barta, P. Litwiński, M. Kawecki, Commentary on Article 5, in: General Data Protection Regulation. Personal Data Protection Act. Selected sectoral provisions. Commentary, ed. P. Litwiński, Legis 2021) "(...) the obligation to ensure appropriate technical and organizational measures referred to in Article 32(1) [of Regulation 2016/679] is dynamic (...), as the EU legislator requires regular testing, measuring, and assessing the effectiveness of the measures applied to ensure security to a degree commensurate with the risk."

It should also be noted that the supervisory authority during the

****Proceedings**** took into account the fact that the Company obtained a certificate regarding the ISO/IEC 27001:2013 standard; however, this does not mean that the Company has fulfilled the requirements of Regulation 2016/679, as it did not provide evidence of properly conducting a risk analysis and regularly testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processing, only indicating a one-time execution of these processes during the recertification audit. These omissions, in turn, led to the improper selection of organizational and technical measures aimed at ensuring the security of data processed by the Company.

From the explanations provided by the Company during the inspection, as well as after its completion, it follows that actions aimed at ensuring regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processing were only undertaken after a personal data breach occurred, albeit to an insufficient extent. The administrator is obliged to verify both the selection and the level of effectiveness of the solutions used at every stage of processing. The complexity of this verification should be assessed through the lens of adequacy to risks and proportionality in relation to the state of technical knowledge, implementation costs, and the nature, scope, context, and purposes of processing. In the factual state at hand, it must therefore be recognized that the Company did not fulfill the aforementioned obligation.

Taking into account the findings made, it should also be acknowledged that the lack of regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processed data was a consequence of the failure to implement adequate organizational measures, i.e., the omission of detailed provisions regarding regular testing, measuring, and assessing the applied technical and organizational measures in the developed and implemented documentation regulating the data processing process in A. Joint Stock Company. The Company did not apply appropriate organizational measures for the security of personal data processing, i.e., it did not include detailed provisions regarding regular testing, measuring, and assessing the applied technical and organizational measures in the developed and implemented documentation regulating the data processing process in A. Joint Stock Company, particularly in § (...) of the procedure titled "Management (...)", entitled "Security (...)", and furthermore, it did not implement as an administrator appropriate organizational measures to ensure – taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity of threat – a level of security corresponding to that risk, including, where appropriate, regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processing. The developed and implemented documentation describing the data processing process in the Company did not contain detailed provisions regarding regular testing, measuring, and assessing the effectiveness of the applied technical and organizational measures. For example, in § (...), and particularly in § (...) of the procedure titled "Management (...)", entitled "Security (...)", there is a provision stating that the Company's IT Department supervises the equipment. This includes, among other things, the control of system security and software control (installation, uninstallation, and updates). However, the aforementioned procedure does not contain regulations concerning specific actions that make up the control, the frequency, forms, and methods of their execution, as well as the manner and form of preparing and storing reports from the aforementioned controls. Furthermore, the regulations applied by the Company did not sufficiently specify which individuals are responsible for conducting the controls, as well as for interpreting the control reports and taking appropriate actions to rectify any irregularities identified during the aforementioned controls.

It should be noted that the violation of Article 32(1)(d) of Regulation 2016/679 in connection with the omission of detailed provisions regarding regular testing, measuring, and assessing the effectiveness of the applied technical and organizational measures in the developed and implemented documentation regulating the data processing process in the Company, particularly in § (...) of the procedure titled "Management (...)", entitled "Security (...)", is reflected – contrary to the Company's assertion – in the content of the aforementioned provision.

Since regular testing, measuring, and assessing the applied technical and organizational measures in the Company, in light of Article 32(1)(d) of Regulation 2016/679, is meant to ensure a level of security corresponding to the risk of infringement of the rights or freedoms of data subjects as a result of their processing, the manner, form, frequency, or timing of conducting the aforementioned activities should be specified in the content of the relevant procedures and in accordance with the results obtained in the conducted risk analysis. Specificity should also be applied to issues such as the manner of reporting the aforementioned activities, storing reports, and the remedial actions taken based on those

reports.

In other words, a vague and general regulation of the issues of testing, measuring, and assessing technical and organizational measures in the titled "Security (...)" § (...) of the procedure titled "Management (...)" does not meet the requirements set forth in the regulation.

"Management (...), without taking into account the aforementioned specific issues, is merely a kind of general declaration and at the same time a repetition of the applicable Article 32(1)(d) of Regulation 2016/679. Therefore, if the performance of the aforementioned activities is to be regular and effectively implemented in the Company's operations, such implementation requires procedural specification and detailing in the description of methods, ways, or frequency of carrying out these activities. Such specification and detailing ensuring the regularity of the aforementioned activities is lacking in the Company's procedure, which consequently constitutes a violation of Article 32(1)(d) of Regulation 2016/679, especially since the Company processes data on a large scale (which the Company confirmed in its explanations), and the processed data also includes data subject to special protection, as referred to in Article 9(1) of Regulation 2016/679 (concerning health).

Importantly, the provisions cited by the Company in its explanations following the inspection (letter dated (...) 2022) of the (...) Policy (...) also do not contain the necessary specification or detailing of the procedures for testing, measuring, and assessing the effectiveness of the applied technical and organizational measures. The content of the aforementioned provisions of the Security Policy contains general, declarative commitments to carry out the relevant activities, without indicating their technical details, such as deadlines, methods, frequency, storage of reports, etc. They therefore represent a minor specification of the obligation formulated in Article 32(1)(d) of Regulation 2016/679, but are far from sufficient, as they reduce to general statements that certain issues are controlled or supervised, and that actions are taken to ensure security, etc. Thus, the content of the provisions indicated by the Company cannot be considered as a manifestation of meeting the requirement of Article 32(1)(d) of Regulation 2016/679 regarding the obligation of regular testing, measuring, and assessing the effectiveness of the applied organizational and technical measures.

The provisions included in the documentation concerning the protection of data processed by the administrator, which serves de facto as the data protection policy indicated in Article 24(2) of Regulation 2016/679, cannot merely constitute a kind of copy of the provisions of the aforementioned regulation, as otherwise they become practically useless. The aim of the European legislator in creating the provisions of Regulation 2016/679, particularly Articles 32 and 24, was to impose on administrators the obligation to apply measures corresponding to the specifics of the individual processing processes occurring for each of them. This therefore determines the obligation on the part of administrators to shape the content of the procedures they use as part of the data protection policy so that they are tailored to the processing activities occurring at those administrators.

Since regular testing, measuring, and assessing the applied technical and organizational measures in the Company, in light of Article 32(1)(d) of Regulation 2016/679, is to ensure a level of security corresponding, among other things, to the risk of infringement of the rights or freedoms of data subjects as a result of their processing, the manner, form, frequency, or deadlines for carrying out the aforementioned activities should be specified in the content of the relevant procedures and in accordance with the results obtained in the conducted risk analysis. Specificity should also be applied to issues such as the method of reporting the aforementioned activities, storing reports, as well as the remedial actions taken based on those reports.

As indicated by the Provincial Administrative Court in its judgment of October 21, 2021 (case reference: II SA/Wa 272/21), "The Court agrees with the position of the President of the UODO (...), that conducting tests only in the event of an emerging threat, without introducing a procedure that would define a schedule of actions ensuring regular testing, measuring, and assessing the effectiveness of the implemented measures is insufficient."

Improper conduct of the risk analysis resulting in the selection of inappropriate security measures and the lack of regular testing, measuring, and assessing by the Company of the effectiveness of the

implemented technical and organizational measures intended to ensure the security of processing significantly increased the risk of infringement of the rights or freedoms of data subjects, and additionally constituted a violation by the Company of its obligations arising from Articles 24(1) and 32(1) and (2) of Regulation 2016/679, and consequently also the principle of integrity and confidentiality expressed in Article 5(1)(f) of Regulation 2016/679.

Along with the violation of the principle of integrity and confidentiality, there was also a violation of the principle of accountability referred to in Article 5(2) of Regulation 2016/679. As indicated by the Provincial Administrative Court in Warsaw in its judgment of February 10, 2021 (case reference: II SA/Wa 2378/20, Legalis No. 2579568), "(...) the data controller is responsible for complying with all principles when processing personal data (listed in Article 5(1)) and must be able to demonstrate compliance. The principle of accountability thus relies on the legal responsibility of the controller for properly fulfilling obligations and imposes on them the duty to demonstrate, both to the supervisory authority and to the data subject, evidence of compliance with all data processing principles." Similarly, this issue was interpreted by the Provincial Administrative Court in Warsaw on August 26, 2020 (case reference: II SA/Wa 2826/19, Legalis No. 2480051), stating that "[t]aking into account the entirety of the norms of Regulation 2016/679, it should be emphasized that the controller has considerable freedom in the scope..."

of relevance to the case, or have already been established by other evidence. Therefore, the President of the UODO concluded that the evidence requests submitted by the Company do not warrant consideration.

The Company's assertion that similar, or even more serious, violations occur in other entities operating in the medical services market does not diminish, let alone absolve, the Company's responsibility for the identified violations of the provisions of Regulation 2016/679. The Provincial Administrative Court in Warsaw, in its judgment of January 19, 2021 (case no. II SA/Wa 702/20, Legalis no. 2821108), emphasized that "(...) the data controller should adequately secure personal data against accidental loss using appropriate technical and organizational measures. Personal data should be processed in a manner that ensures their appropriate security and confidentiality, including protection against unauthorized access to them and to the equipment used for their processing, as well as against unauthorized use of such data and equipment (recital 39 of Regulation 2016/679). (...) the data controller is responsible not only for the actions of its employees but also for the processing of data in the IT system it uses."

It should also be noted that the explanations provided by the Company in its letter dated (...) 2022 indicate that it has taken remedial actions regarding the violations identified during the inspection by the President of the UODO. However, it should be emphasized that these actions did not cover all the violations of the provisions of Regulation 2016/679 identified during the UODO inspection and which are the subject of this decision. Therefore, considering that the Company continues to process personal data, particularly without developing and implementing a detailed procedure regarding regular testing, measuring, and evaluating the effectiveness of technical and organizational measures aimed at ensuring the security of processing (and also not actually performing the aforementioned activities), as well as without updating the software of the edge devices used in the Company's IT system in accordance with the manufacturer's update plan, the President of the UODO, based on Article 58(2)(d) of Regulation 2016/679, ordered it to implement appropriate technical and organizational measures to minimize the risks associated with the processing of personal data, particularly those arising from accidental or unlawful destruction, loss, modification, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed, after conducting a risk analysis that takes into account the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons, and to implement appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of measures aimed at ensuring the security of processing.

Referring to the content of the Company's letters dated (...) 2023 and (...) 2023, which contain

evidence requests from the parties to the proceedings, the President of the UODO found that these requests do not merit consideration. According to Article 78 § 1 of the Administrative Procedure Code (Kpa), a party's request for the presentation of evidence should be granted if the subject of the evidence is a circumstance relevant to the case. Furthermore, in accordance with Article 78 § 2 of the Kpa, a public administration authority may disregard a request (§ 1) that was not raised during the evidence presentation or at the hearing if the request pertains to circumstances already established by other evidence, unless they are significant for the case. Conversely, according to Article 75 § 1 of the Kpa, any evidence that may contribute to clarifying the case and is not contrary to law should be admitted. In particular, evidence may consist of documents, witness testimonies, expert opinions, and inspections.

In the case of evidence requests submitted by the Company, the subject of the evidence should be circumstances that, in the opinion of the President of the UODO, either do not have relevance to the case or have already been established by other evidence.

the effects of the hacking attack – the requested evidence cannot contribute to clarifying the case due to the fact that the circumstances to be established by the above-mentioned evidence have already been determined by other evidence, including the protocols of the oral explanations received with the participation of P. K. during the control activities of the authority, as well as in the post-control written explanations of the Company, or the subject of the evidence is a circumstance that is not relevant to the case;

3) evidence from a document, i.e., the request made by the Company to the Provincial Police Commander in K., under Article 76a § 1 of the Code of Administrative Procedure, requesting copies or the delivery of original documents contained in the investigation files regarding the case with the reference number (...) conducted by the Department (...), including in particular the decision of (...) 2022 regarding the discontinuation of the investigation into the event related to the event that is the subject of these proceedings – the subject of the evidence is a circumstance that is not relevant to the case due to the violations of the provisions of Regulation 2016/679 established by the President of the Personal Data Protection Office, which are themselves the subject of resolution in the decision, regardless of their impact on the course of the data protection violation, as well as regardless of the ruling in this matter by the competent authority regarding the commission or non-commission of an offense within the meaning of criminal law provisions, as the above does not affect the assessment by the President of the Personal Data Protection Office of the actions of the Company as the administrator in light of the provisions of Regulation 2016/679; for the reasons stated above, the outcome of the criminal proceedings does not affect the administrative proceedings regarding the violation of the provisions of Regulation 2016/679,

4) the admission and conduct of evidence under Article 75 § 1 of the Code of Administrative Procedure from the documents contained in the investigation files regarding the case with the reference number (...) conducted by the Department (...), including in particular the decision of (...) 2022 regarding the discontinuation of the investigation into the event related to the event that is the subject of these proceedings concerning the following circumstances: their content, the scale of the hacking attack, the inability to identify the perpetrators, the inability to determine the technical methods of the hackers' actions, the organized and highly specialized actions of the unidentified perpetrators of the hacking attack, the actions taken by the Company to minimize the effects of the hacking attack – the requested evidence cannot contribute to clarifying the case due to the fact that the circumstances to be established by the above-mentioned evidence have already been determined by other evidence, including the protocols of the oral explanations received with the participation of P. K. during the control activities of the authority, as well as in the post-control written explanations of the Company. effects of a hacker attack – the subject of evidence should be circumstances that are irrelevant to the case due to violations of the provisions of Regulation 2016/679 identified by the supervisory authority, which in themselves will be the subject of a decision, regardless of their impact on the course of the personal data breach, as well as regardless of the content of the ruling issued in this matter by the competent authority regarding the commission or non-commission of an offense within the meaning of

criminal law, as such a ruling does not affect the assessment of the Company's actions as an administrator in light of the provisions of Regulation 2016/679, conducted by the President of the UODO; for the reasons indicated above, the outcome of the criminal proceedings does not affect the administrative proceedings concerning the violation of the provisions of Regulation 2016/679. Furthermore, some of the above circumstances have been established by other evidence, namely described, among others, in the records of oral explanations received from the Company's employees during the supervisory authority's control activities.

In this regard, it cannot be agreed with the Company's assertion contained in the letter dated (...) 2023, that the issuance of this decision occurred on the basis of "incomplete evidence material, which does not allow for a full reconstruction of the objective course of events, would violate the principle of objective truth (Article 7 of the Code of Administrative Procedure) and the principle of citizens' trust in public authority (Article 8 of the Code of Administrative Procedure), as well as the standards of fair administrative proceedings."

According to Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of the measures referred to in Article 58(2) of Regulation 2016/679, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. Considering the identified violations of the provisions of Regulation 2016/679, the President of the UODO, exercising the powers granted to him under the aforementioned provision, determined that in the case at hand there were grounds justifying the imposition of an administrative fine on the Company. Accordingly, under the provisions of Article 83(2) of Regulation 2016/679, administrative fines are imposed, depending on the circumstances of each individual case, in addition to or instead of the measures referred to in Article 58(2)(a)-(h) and (j) of Regulation 2016/679.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions shaping the obligations of the controller and the processor, referred to in Articles 8, 11, 25-39, and 42 and 43, are subject to an administrative fine of up to EUR 10,000,000, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. Pursuant to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, are subject to an administrative fine of up to EUR 20,000,000, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Moreover, Article 83(3) of Regulation 2016/679 states that if the controller or processor intentionally or unintentionally violates several provisions of Regulation 2016/679 within the same or related processing operations, the total amount of the administrative fine shall not exceed the amount of the fine for the most serious violation.

In this administrative proceeding, the administrative fine imposed on the Company was for the violation of Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679 it was based on Article 83(5)(a) of Regulation 2016/679. At the same time, the fine imposed on the Company for the violation of all the above provisions, in accordance with Article 83(3) of Regulation 2016/679, does not exceed the amount of the fine for the most serious violation identified during the proceedings, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which according to Article 83(5)(a) of Regulation 2016/679 is subject to an administrative fine of up to EUR 20,000,000, and in the case of an enterprise – up to 4% of its total worldwide turnover from the previous financial year.

In deciding to impose an administrative fine, the President of the UODO – in accordance with Article 83(2)(a) – (k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in the present case and which weigh heavily on the amount of the imposed administrative fine:

a) the nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of

the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). The violation of the provisions and principles concerning the protection of personal data in connection with their processing by the Company in the course of its business activities in the field of medical services without implementing adequate technical and organizational measures, including those supported by its manufacturer with system software updates for edge devices (violation of Article 32(1) and (2) of Regulation 2016/679), is significant, due to the considerable scale of data processing by the Company and the type of services it provides.

business activities, and consequently the scope of processed data (data of special categories, including, among others, health data). It should be emphasized once again that the Company provides medical services in Poland, including in the area of (...). This fact determines the scope of data processed by it, the disclosure of which may cause particular harm to the individuals concerned. It should also be noted that the data processed by the Company constitutes medical secrecy, which also affects the necessity of accepting the significant nature and weight of the breach.

Furthermore, the violations of the provisions of Regulation 2016/679 identified during the inspection and subsequently in the course of the administrative proceedings were associated with a breach of the principle of integrity and confidentiality (Article 5(1)(f) of Regulation 2016/679), i.e., the obligation to process personal data in a manner that ensures appropriate security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures, as well as the principle of accountability (Article 5(2) of Regulation 2016/679), which made them significant and serious due to the fact that all the aforementioned organizational and technical measures are fundamental to ensuring the security of data processing in technical (e.g., implementing software updates) and organizational (implementing a detailed procedure for regular testing, measuring, and assessing the effectiveness of technical and organizational measures) terms.

The breach of personal data protection regulations established in this case, which resulted in an increased risk of unauthorized access to personal data processed by the Company in the IT system by third parties, is serious and significant also because it creates a high risk of negative legal consequences for, among others, (...) individuals whose data lost confidentiality due to the breach of personal data protection. The Company's failure to fulfill its obligation to implement appropriate security measures to protect processed data from unauthorized disclosure not only entailed a potential but also a real possibility of their use by third parties in violation of the provisions of Regulation 2016/679 without the knowledge and against the will of the individuals concerned, e.g., for the purpose of establishing legal relations or incurring obligations on their behalf.

In this case, there is no evidence indicating that the individuals (patients, employees of the Company) whose data were accessed by third parties suffered property damage; however, the mere breach of confidentiality of their data constitutes non-material damage (harm) for them, e.g., through the violation of their personal rights, such as mental well-being, the right to privacy, etc. Individuals whose data were unlawfully obtained as a result of a breach of personal data protection may at least feel fear of losing control over their personal data, identity theft or identity fraud, discrimination (health data), or finally – financial loss. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case no. XXV C 2596/19, fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its judgment of December 14, 2023, in the case of Natsionalna agentsia za prihodite (C-340/21) emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which the data subject experiences as a result of a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

The processing of data in violation of the provisions of Regulation 2016/679 has been occurring since the date of the commencement of the application of the provisions of Regulation 2016/679, i.e., since May 25, 2018, due to the content of the document "(...)" prepared as of (...) 2020 and the document "(...)" prepared as of (...) 2018 with an update on (...) 2019 (whereby, in connection with the use of the

system (...) despite the lack of technical support from the manufacturer, the violation of the provisions occurred from (...) 2020) and continues due to the failure to eliminate all identified deficiencies in the security measures during the inspection.

b) the unintentional nature of the breach (Article 83(2)(b) of Regulation 2016/679). The Company indicated in its written explanations dated (...) 2022 that its actions were not intentional and that it had taken corrective actions to minimize the risk of reoccurrence of the breach. The evidence collected during the inspection and the explanations provided by the Company in the aforementioned letter indicate that the Company did not consciously use IT resources that lacked current support from their manufacturers, as the members of its management board were not aware of this, although the employees of the Company's IT department were.

In this regard, it should be stated that the members of the Company's management board should have been aware of this as well; thus, the lack of internal communication between the Company's employees and its management is itself an additional circumstance burdening the Company in this case, rather than justifying its stance and mitigating it. The above seems to indicate errors in the management of the Company, which translated into the violations of the provisions of Regulation 2016/679 indicated in this decision. The potential impact on the above factual state may also have been influenced by the lack of appropriate, specific procedural provisions relating to

****Issues of Regular Testing, Measuring, and Assessing the Effectiveness of Organizational and Technical Measures****

Implemented by the Company to ensure adequate protection of the data processed by it. The Company was aware that in the case of allowing the processing of personal data on such a broad scale, it should ensure appropriate security for that data, including protection against unauthorized or unlawful processing, through appropriate technical and organizational measures, and thus in such a way that the processing occurs in accordance with the principle of integrity and confidentiality expressed in Article 5(1)(f) of Regulation 2016/679.

Knowing the nature and specificity of such processes, the Company should have excluded the possibility of potential breaches of personal data protection due to the specificity of the operation of information systems, in which human error (lack of software updates, incorrect system configuration, etc.) must always be taken into account. Despite the adopted practice of using such systems for processing personal data, the Company did not properly conduct a risk analysis in the area covered by the breach of personal data protection, not only until the occurrence of the breach but even after it (e.g., regarding the use of outdated software). In this case, the Company should have considered that the adopted solutions do not ensure an adequate level of security for personal data, which may lead to a breach of personal data protection regulations.

Considering the findings in the matter subject to the resolution of this decision, it should be stated that the Company was not aware of the above-mentioned circumstances and therefore did not act intentionally; however, it committed negligence resulting in a significant increase in the risk of breach of the availability and confidentiality of the processed data, which constitutes a significant circumstance affecting the severity of the administrative monetary penalty.

c) All relevant previous violations by the administrator (Article 83(2)(e) of Regulation 2016/679). When making a decision on the imposition and amount of the administrative monetary penalty, the supervisory authority is obliged to take into account any previous violations of Regulation 2016/679. The EDPB in Guidelines 04/2022 on calculating administrative monetary penalties under the GDPR adopted on May 24, 2023, hereinafter referred to as Guidelines 04/2022, explicitly states: "The existence of previous violations can be considered an aggravating factor when calculating the amount of the monetary penalty. The weight attributed to this factor should be determined taking into account the nature and frequency of previous violations. The absence of previous violations cannot, however, be considered a mitigating circumstance, as compliance with the provisions of [Regulation 2016/679] is the norm." And although, as indicated in the aforementioned guidelines, "greater importance should be attributed to violations concerning the same subject matter, as they are closer to the violation that is

the subject of the current proceedings, especially when the administrator or processor has previously committed the same violation (repeated violations)" (point 88 of the guidelines), all previous violations may constitute information about the overall approach of the administrator or processor to compliance with the provisions of Regulation 2016/679.

The supervisory authority has already established in previously issued administrative decisions that the Company violated personal data protection regulations: 1) in the decision of (...) 2022 (ref. (...)) – violation of Article 6(1), Article 5(1)(a), and (b) of Regulation 2016/679; 2) in the decision of (...) 2021 (ref. (...)) – violation of Article 5(1)(c) and Article 9(1) of Regulation 2016/679; 3) in the decision of (...) 2021 (ref. (...)) – violation of Article 5(1)(c) and Article 9(1) of Regulation 2016/679; 4) in the decision of (...) 2021 (ref. (...)) – violation of Article 5(1)(a) and Article 9(1) of Regulation 2016/679; 5) in the decision of (...) 2021 (ref. (...)) – violation of Article 5(1)(a) and Article 9(1) of Regulation 2016/679.

The aforementioned previous violations of the provisions of Regulation 2016/679 indicate a generally negligent approach of the Company to data protection issues, and the remedial measures previously applied to it in the aforementioned cases, i.e., a reprimand issued to the Company by the President of the UODO for violating Article 6(1) of Regulation 2016/679, as was the case in the matter with ref. (...), and Article 9(1) of Regulation 2016/679 (cases with ref. (...) and (...)), fully justify the imposition of a financial sanction in this proceeding, as well as its amount.

In light of the above, it should be acknowledged that there are grounds for treating the criterion in Article 83(2)(e) of Regulation 2016/679 as aggravating.

d) The degree of cooperation with the supervisory authority to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The Company provided complete and specific explanations during the inspection regarding the subject of the inspection and the identified breaches of personal data protection regulations, and furthermore, after the inspection, the President of the UODO undertook actions and measures aimed at improving the state of protection of the data processed by it in connection with the breaches of Regulation 2016/679 identified during the inspection. However, the remedial actions were not undertaken to the full extent, i.e., as of the date of this decision, the Company had not developed a procedure for testing, measuring, and assessing the effectiveness of organizational and technical measures for data protection, nor had it actually carried out the aforementioned activities on a regular basis. For this reason, the degree of cooperation of the Company with the supervisory authority in order to...

removal of the violation and mitigation of its potential negative effects should be assessed as not fully satisfactory, and thus it constitutes a burden on the Company when determining the amount of the administrative monetary penalty.

e) categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679). Among the personal data processed by the Company, in addition to so-called ordinary data such as: first name, last name, parents' names, date of birth, bank account number, residential or stay address, PESEL identification number, email address, username or password, salary or asset information, mother's maiden name, series and number of the identity card, and phone number, there were also special categories of data, i.e., health-related data, as referred to in Article 9(1) of Regulation 2016/679.

In light of the above, the Company, when processing personal data of the aforementioned categories, should demonstrate at least due diligence and special care in complying with the provisions of data protection law, as any breach of confidentiality, integrity, or availability of the aforementioned data is associated with particularly high risks of violating the rights or freedoms of the data subjects, as well as the possibility of causing them harm. The Company, by underestimating some of the aforementioned risks, the implementation of system software updates, procedures regarding regular testing, measuring, and assessing the effectiveness of technical and organizational measures, and the proper configuration of the aforementioned systems, thus failed to exercise due diligence in ensuring the security of this data.

It should be noted that among the personal data processed by the Company is also the PESEL

identification number. Although it does not belong to the category of special data referred to in Article 9(1) of Regulation 2016/679, it should be emphasized that in particular, unauthorized disclosure of the PESEL identification number along with the first name and last name, which unequivocally identify a natural person, can realistically and negatively affect the protection of the rights or freedoms of that person. As indicated by the Provincial Administrative Court in Warsaw in its judgment of July 1, 2022 (case no. II SA/Wa 4143/21, Legalis no. 2760091), “[i]n the case of a breach of such data as first name, last name, and PESEL number, identity theft or forgery is possible through obtaining loans from non-bank institutions or fraudulently obtaining insurance or funds from insurance, which may lead to negative consequences related to attempts to attribute responsibility for such fraud to the persons whose data have been breached.”

It should therefore be recognized that the PESEL identification number, which is an eleven-digit numerical symbol that unequivocally identifies a natural person, containing, among other things, the date of birth and gender designation, and thus closely related to the private sphere of the natural person and also subject, as a national identification number, to protection under Article 87 of Regulation 2016/679, is data of a special nature and as such requires equally special protection.

As indicated in the EROD Guidelines 04/2022 (p. 22), “Regarding the requirement to take into account the categories of personal data affected by the breach (Article 83(2)(g) of the GDPR), the GDPR clearly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 of the GDPR and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers).

In general, the more categories of such data are affected by the breach or the more sensitive the data, the greater weight the supervisory authority may assign to this factor.”

In deciding to impose an administrative monetary penalty, the President of the UODO took into account the following circumstances of the case that mitigate the severity of the imposed administrative monetary penalty:

a) actions taken by the controller to minimize the harm suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). According to the content of the supplementary notification of the data protection breach, which was submitted to the President of the UODO on (...) 2021, the data subjects, in relation to whom it was unequivocally established that their personal data were affected by this breach, received notifications indicating the possible risks associated with this breach and suggested remedial measures. In relation to individuals for whom the disclosure of the PESEL number and identity card was confirmed, the controller offered to cover the cost of BIK reporting. The Company sent three types of notifications to the data subjects – a notification to the patient, a notification to the employee, and notifications to the employee also including a notification of the disclosure of the identity card number. The employees of the Company received a message reminding them of their obligations regarding protected information, including the protection of personal data.

The above actions of the Company should be assessed as appropriate and proportional to the degree of non-material harm caused to the data subjects, therefore they should be positively evaluated and taken into account when estimating the amount of the imposed administrative monetary penalty.

Other circumstances, as indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the established breach in this case, were considered by the President of the UODO to be neutral in his assessment.

meaning neither aggravating nor mitigating the imposition of the administrative monetary penalty.

a) the degree of responsibility of the administrator, taking into account the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). Some of the technical and organizational measures aimed at protecting personal data processed by

the Company were insufficient and not implemented (primarily errors in the risk analyses conducted, errors in the configuration of IT equipment, lack of updates to system software, and lack of procedures for testing, measuring, and assessing the effectiveness of technical and organizational measures). For this reason, the degree of the Company's responsibility for the factual situation is high. The Company was aware of the necessity, e.g., to update system software. The above should also be related to the issue of underestimating certain risks, the lack of procedures for testing, measuring, and assessing technical and organizational measures, as well as the lack of proper configuration of the aforementioned systems. In this case, it is impossible to attribute responsibility for the violations of the provisions of Regulation 2016/679 to entities other than the Company or to assume the occurrence of force majeure. As indicated by the Article 29 Working Party (Guidelines on the application and setting of administrative fines for the purposes of Regulation No. 2016/679 adopted on October 3, 2017, 17/PL, WP 253, hereinafter referred to as the "WP 253 Guidelines"), when considering the above premise, "the supervisory authority must answer the question of the extent to which the administrator 'did everything that could be expected,' considering the nature, purposes, or scope of processing and in light of the obligations imposed on him by the regulation."

The supervisory authority found in this case that the Company violated the provisions of Article 32(1) and (2) of Regulation 2016/679. In its opinion, the Company bears a high degree of responsibility for failing to implement appropriate technical and organizational measures that could have prevented the violation of personal data protection. It is therefore evident that in the considered context of the nature, purpose, and scope of processing personal data, the Company did not do everything that could be expected, thus failing to fulfill the obligations imposed on it under Article 32 of Regulation 2016/679. However, in this case, this circumstance constitutes the essence of the violation itself – it is not merely a factor influencing – aggravating or mitigating – its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Article 32 of Regulation 2016/679 cannot be considered in this case as a circumstance that could additionally influence the assessment of the violation and the extent of the administrative monetary penalty imposed on the Company.

b) the manner in which the supervisory authority became aware of the violation, in particular, whether and to what extent the administrator reported the violation (Article 83(2)(h) of Regulation 2016/679). The President of UODO found that the Company violated the provisions on personal data protection as a result of the report of the personal data breach made by the Company and the conducted inspection. By making the report, the Company fulfilled its legal obligation, and therefore there are no grounds to consider this fact as a mitigating circumstance. As indicated by EROD in the Guidelines 04/2022 (p. 32), "According to Article 83(2)(h), the manner in which the supervisory authority became aware of the violation may constitute a significant aggravating or mitigating factor. In assessing this aspect, particular weight may be given to the question of whether the administrator or processor notified of the violation on their own initiative, and if so, to what extent, before the supervisory authority was informed of the violation through – for example – a complaint or investigation. This circumstance is irrelevant when the administrator is subject to special obligations regarding the reporting of violations (such as the obligation to report a personal data breach specified in Article 33). In such cases, the fact of making the report should be considered a neutral circumstance."

c) if measures referred to in Article 58(2) have been previously applied to the administrator in the same case – compliance with these measures (Article 83(2)(i) of Regulation 2016/679). Before issuing this decision, the President of UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 to the Company in the examined case, which means that the Company had no obligation to take any actions related to their implementation, and such actions, subject to the assessment of the supervisory authority, could have an aggravating or mitigating impact on the assessment of the identified violation.

d) the application of approved codes of conduct under Article 40 or approved certification mechanisms under Article 42 (Article 83(2)(j) of Regulation 2016/679). As of the date of the decision, the Company did not apply any approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not

mandatory for administrators, as stipulated by the provisions of Regulation 2016/679, which means that the circumstance of their non-application cannot be considered against the Company in this case. Conversely, the circumstance of adopting and applying such instruments could be taken into account in favor of the Company, as measures guaranteeing a higher than standard level of protection for the processing of personal data.

e) any other aggravating or mitigating factors applicable to the circumstances of the case, such as achieved directly or indirectly in connection with the violation of financial benefits or avoidance of loss (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not find that the Company gained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to consider this circumstance as aggravating for the Company. The determination of the existence of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed decidedly negatively. The Company's failure to achieve such benefits, as a natural state independent of the violation and its consequences, is a circumstance that, by its very nature, cannot be mitigating for the Company. This interpretation is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" – that is, those that occurred on the part of the entity committing the violation.

The President of the UODO, having comprehensively considered the matter, did not note any circumstances other than those described above that could affect the assessment of the violation and the amount of the imposed administrative monetary penalty. In particular, in response to the Company's letter dated (...) 2022, in which it stated that, similar to the case with reference number (...), the violation of personal data protection occurred during the COVID-19 pandemic, i.e., under conditions of the Company's personnel being engaged in actions aimed at countering its effects, which constitutes a mitigating circumstance in this case, it should be pointed out that the President of the UODO cannot agree with this view of the Company. The circumstance of the occurrence of a violation of personal data protection during the COVID-19 pandemic does not constitute a mitigating circumstance in this case because the negligence identified by the President of the UODO on the part of the Company, which also constitutes a violation of the provisions of Regulation 2016/679, had no connection with the aforementioned pandemic, and the state of violation existed even before its onset. Thus, the pandemic circumstances could not have influenced all of the Company's omissions in the field of personal data security. The significant engagement of the Company's IT services in various actions related to the outbreak of the pandemic is therefore not a justification in light of the identified irregularities that occurred both before and during the pandemic.

Considering all the circumstances discussed above, the President of the UODO concluded that imposing an administrative monetary penalty on the Company is necessary and justified by the gravity, nature, and scope of the violations attributed to the Company. It should be stated that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679, particularly merely issuing a reprimand (Article 58(2)(b) of Regulation 2016/679), would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the Company would not commit further negligence in the future.

Regarding the amount of the administrative monetary penalty imposed on the Company, it should be noted that in the established circumstances of this case, given the identified violations of several provisions of Regulation 2016/679, namely the principle of integrity and confidentiality of data, expressed in Article 5(1)(f) of Regulation 2016/679, and reflected in the form of obligations defined in Article 32(1) and (2) of Regulation 2016/679, and consequently also Article 5(2) of Regulation 2016/679, which regulates the principle of accountability, Article 83(4)(a) and (5)(a) of Regulation 2016/679 will apply.

According to the provisions of Article 103 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781), hereinafter referred to as the Act of May 10, 2018, the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate

table on January 28 of each year, and in the event that in a given year the National Bank of Poland does not announce the average euro exchange rate on January 28 – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date. In 2024, the average euro exchange rate was announced by the National Bank of Poland on January 29, 2024, at the rate of 1 EUR = 4.3653 PLN.

Having the above in mind, the President of the UODO, based on Article 83(3) and Article 83(5)(a) of Regulation 2016/679 in connection with Article 103 of the Act on the protection of personal data, for the violations described in the operative part of this decision, imposed on the Company – applying the average euro exchange rate announced by the National Bank of Poland on January 29, 2024 (1 EUR = 4.3653 PLN) – an administrative monetary penalty in the amount of 1,440,549.00 PLN (in words: one million four hundred forty thousand five hundred forty-nine zlotys), which constitutes the equivalent of 330,000 EUR (in words: three hundred thirty thousand euros).

It is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of the UODO applied the methodology adopted by the European Data Protection Board in Guidelines 04/2022. According to the guidance presented in this document:

1. The President of the UODO categorized the identified violations of the provisions of Regulation 2016/679 in this case (see Chapter 4.1 of Guidelines 04/2022). Among the provisions of Regulation 2016/679 violated by the Company are the provisions of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which define the basic principles of processing. Violations of these provisions fall – according to Article 83(5)(a) of Regulation 2016/679 – into the category of violations subject to a higher penalty of the two dimensions of penalties provided for in Regulation 2016/679 (with a maximum amount of up to 20,000,000 EUR or up to 4%...

****Total Annual Turnover of the Enterprise****

from the previous financial year). They are therefore in abstracto more serious than other violations (indicated in Article 83(4) of Regulation 2016/679).

2. The President of the UODO assessed the violations identified in this case (in particular, violations of the fundamental principles of processing) as violations of medium severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the criteria listed in Article 83(2) of Regulation 2016/679 that pertain to the subject matter of the violations (constituting the "seriousness" of the violation), namely: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83(2)(g) of Regulation 2016/679) were taken into account. A detailed assessment of these circumstances has been presented above. It should be noted that considering their cumulative impact on the assessment of the violation identified in this case leads to the conclusion that the level of its seriousness (understood in accordance with Guidelines 04/2022) is medium. Consequently, the starting amount for calculating the fine is accepted to be within the range of 10% to 20% of the maximum fine that can be imposed on the Company, that is – considering the limit set out in Article 83(5) of Regulation 2016/679 – from the amount of 2,000,000 EUR to the amount of 4,000,000 EUR (see Subchapter 4.2.4 of Guidelines 04/2022). The President of the UODO considered the starting amount of 3,000,000 EUR (equivalent to 13,095,900 PLN) to be adequate and justified by the circumstances of this case.

3. The President of the UODO adjusted the starting amount corresponding to the medium severity of the identified violation to the Company's turnover as a measure of its size and economic strength (see Chapter 4.3 of Guidelines 04/2022). According to Guidelines 04/2022, in the case of enterprises with an annual turnover of up to 100 – 250 million EUR, the supervisory authority may consider further calculations of the fine based on a value ranging from 15% to 50% of the starting amount. Given that the turnover (revenue) of the Company in 2022 amounted to (...),- PLN, which is approximately (...) EUR (according to the average EUR exchange rate on January 29, 2024), the President of the UODO deemed it appropriate to adjust the amount subject to calculations to a value corresponding to 20% of the starting amount, that is to the amount of 600,000 EUR (equivalent to 2,619,180 PLN).

4. The President of the UODO assessed the impact on the identified violation of other circumstances (besides those considered above in the assessment of the severity of the violation) indicated in Article

83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by Guidelines 04/2022 – to the subjective side of the violation, that is to the entity itself that committed the violation and to its behavior before the violation, during it, and after its occurrence. A detailed assessment and justification of the impact of each of these criteria on the assessment of the violation have been presented above. The criteria (from Article 83(2)(d), (e), (h), (i), (j), (k) of Regulation 2016/679) – as indicated above – did not have any impact, either mitigating or aggravating, on the assessment of the violation and consequently on the imposition of the fine.

5. The President of the UODO stated that the amount of the administrative fine determined in the manner presented above does not exceed – in accordance with Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the fine provided for the most serious violation (see Chapter 6 of Guidelines 04/2022). As indicated above, the most serious violation in this case is the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which is subject to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total annual global turnover from the previous financial year, with the higher amount applying. The President of the UODO determined that the "dynamic maximum amount" for this violation and for this perpetrator expressed as a percentage (...%) of its turnover would amount to (...) EUR, which means that in this case – as the higher amount – the "static maximum amount" for the examined violation is 20,000,000 EUR. The aforementioned amount of 600,000 EUR clearly does not exceed the amount of 20,000,000 EUR.

6. Although the amount of the fine determined according to the above principles does not exceed the legally defined maximum fine, the President of the UODO considered that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for imposing fines (see Chapter 7 of Guidelines 04/2022). Undoubtedly, a monetary fine of 600,000 EUR would be an effective penalty (due to its severity, it would achieve its repressive goal, which is to punish unlawful behavior) and deterrent (effectively discouraging both the Company and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). However, such a penalty would be – in the opinion of the President of the UODO – a disproportionate penalty due to its excessive severity. The principle of proportionality requires, among other things, that the measures adopted by the supervisory authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity defined by taking into account the circumstances of the specific case" (P. Litwiński (ed.), Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Regulation on Data Protection).

****On the Protection of Personal Data. Selected Sectoral Provisions. Commentary.****

Taking into account the proportionality of the penalty, the President of the UODO further reduced the amount of the fine to 55% of the amount obtained after considering the aggravating and mitigating circumstances (see point 4 above), which amounts to 330,000 EUR (equivalent to 1,440,549.00 PLN). In his opinion, such determination of the final amount of the imposed fine will not affect its effectiveness and deterrent nature. This amount constitutes a threshold above which further increases in the amount of the fine will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the amount of the fine could come at the expense of its effectiveness and deterrent nature, as well as the consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

The deterrent nature of the administrative monetary penalty is associated with preventing violations of the provisions of Regulation 2016/679 in the future and placing greater emphasis on the Company's performance of its duties as a data controller. The penalty is intended to deter both the Company from reoffending and other entities involved in data processing.

In imposing this administrative decision of a monetary penalty for violating personal data protection regulations, the President of the UODO took both aspects into account: firstly, the repressive nature

(the Company violated the provisions of Regulation 2016/679), and secondly, the preventive nature (both the Company and other entities involved in the processing of personal data will perform their obligations arising from Regulation 2016/679 with greater care and due diligence). In other words, in the opinion of the President of the UODO, the administrative monetary penalty will serve a repressive function, as it will be a response to the Company's violation of the provisions of Regulation 2016/679, but also a preventive function, as the Company itself will be effectively discouraged from violating personal data protection regulations in the future.

The purpose of the imposed penalty is to obligate the Company to properly fulfill its obligations arising from Regulation 2016/679, and consequently to conduct data processing processes in accordance with applicable legal provisions. It should be emphasized that the penalty will be effective if its imposition leads to the Company adjusting its data processing processes to a legally compliant state.

The application of an administrative monetary penalty in this case is necessary, considering that the Company processed the data of its patients (in particular, health-related data) without properly conducting a risk analysis, without updating system software, without implementing appropriate procedures for testing, measuring, and assessing technical and organizational measures, as well as proper configuration of the aforementioned systems.

The administrative monetary penalty applied, as demonstrated above, is also proportional to the established violation, particularly in terms of its severity, impact, the circle of affected individuals, and the high risk of negative consequences that they may suffer in connection with the violation. In the opinion of the President of the UODO, the administrative monetary penalty imposed on the Company will not constitute an excessive burden for it. The amount of the penalty has been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of the Company's violation of obligations, while not causing a situation in which the necessity to pay it would lead to negative consequences in the form of a significant deterioration of the Company's financial situation. In the opinion of the President of the UODO, the Company should – and is able to – bear the consequences of its negligence in the area of data protection, which is why he considers the imposition of a penalty in the amount of 1,440,549.00 PLN (in words: one million four hundred forty thousand five hundred forty-nine zlotys) to be fully justified.

In the opinion of the President of the UODO, the administrative monetary penalty applied fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case. Therefore, it should be noted that the administrative monetary penalty in the amount of 1,440,549.00 PLN meets the criteria referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the established violation in the context of the fundamental principles of Regulation 2016/679 – the principles of confidentiality and integrity, as well as the principle of accountability.

In this factual and legal state, the President of the Office for Personal Data Protection has decided as stated in the operative part.

[1] Standard PN-EN ISO/IEC 27002 Chapter 12.5.1 letter a) "Installation of software in production systems."

[2] Guidelines of the European Data Protection Board 01/2021 on examples of reporting personal data breaches adopted on December 14, 2021, version 2.0, chapter 2.5 "Organizational and technical measures to prevent and mitigate the effects of ransomware attacks."

[3] Source: publications from The National Cyber Security Centre, information on the website gov.pl, NIST Digital Identity Guidelines materials published by the FBI as part of the Protected Voices initiative and CERT Polska.

****Print Article****

****Metadata****

****Entity Providing Information:**** Department of Control and Violations

****Information Created By:**** Mirosław Wróblewski

****Date Created:**** 2024-05-20

****Information Entered By:** Wioletta Golańska**

****Date Entered:** 2024-08-13 10:34:16**

****Last Modified By:** Karolina Jastalska**

****Date Last Modified:** 2024-08-13 13:34:48**